

TRƯỜNG ĐẠI HỌC XÂY DỰNG HÀ NỘI
KHOA CÔNG NGHỆ THÔNG TIN



BÁO CÁO

Bài tập lớn môn: An toàn bảo mật thông tin

Đề tài: Tìm hiểu hình thức tấn công DNS Spoofing

Sinh viên thực hiện : Đinh Đình Huy – 0013368

Tô Thái Tuấn – 0027068

Ngô Trung Hiếu – 0010668

Lớp: 68IT4

Giảng viên hướng dẫn: Th.S Nguyễn Việt Nhật

Hà Nội, 04/2025

Mục lục

c

I. Tổng quan	4
1.1 Khái niệm DNS và vai trò của nó	4
1.2 DNS Spoofing là gì?	4
1.3 Mục tiêu của DNS Spoofing	4
1.4 Cơ chế hoạt động của DNS Spoofing	4
1.5 Biểu hiện khi bị DNS Spoofing	5
II. Các hình thức tấn công DNS Spoofing phổ biến	5
2.1 DNS Cache Poisoning (Nhiễm độc bộ nhớ đệm DNS)	5
2.1.1 DNS Cacche Poisoning là gì?	5
2.1.2 Quá trình ngộ độc bộ nhớ đệm xảy ra như thế nào?	6
2.1.3 Tại sao việc đầu độc bộ nhớ đệm DNS lại nguy hiểm?	6
2.1.4 Rủi ro liên quan đến việc đầu độc bộ đệm DNS	7
2.1.5 Các cách để ngăn chặn DNS Cache Poisoning	7
2.2 Man-in-the-Middle DNS Attack (Tấn công trung gian DNS)	8
2.2.1 Man-in-the-Middle DNS Attack là gì?	8
2.2.2 Tiến trình tấn công MITM	9
2.2.3 Các hình thức tấn công Man-in-the-Middle	11
2.2.4 Phòng ngừa tấn công	12
2.3 DNS Hijacking (Chiếm quyền điều khiển DNS)	12
2.3.1 DNS Hijacking là gì?	12
2.3.2 Các loại tấn công chiếm quyền điều khiển DNS	13
2.3.3 Cách phát hiện DNS Hijacking	13
2.3.4 Phương pháp giảm thiểu	14
2.4 Pharming Attack (Tấn công chuyển hướng DNS)	16
2.4.1 Pharming Attack là gì?	16
2.4.2 Cách Pharming hoạt động	16
2.4.3 Các loại Pharming	17
2.4.4 Dấu hiệu của một cuộc tấn công Pharming	19

2.4.5 Làm thế nào để ngăn ngừa Pharming.....	19
2.5 Tấn công DNS Rebinding.....	20
2.5.1 Tấn công DNS Rebinding là gì?.....	20
2.5.2 Cuộc tấn công DNS Rebinding hoạt động như thế nào?.....	21
2.5.3 Rủi ro và lỗ hổng liên kết DNS.....	22
2.5.4 Làm thế nào để ngăn chặn cuộc tấn công DNS Rebinding? ..	23
2.6 Đường hầm DNS (DNS Tunneling).....	24
2.6.1 Đường hầm DNS là gì?.....	24
2.6.2 Đường hầm DNS hoạt động như thế nào.....	25
2.6.3 Ngăn chặn đường hầm DNS.....	26
III. Demo hình thức tấn công.....	26
IV. Kết luận.....	30
Tài liệu tham khảo.....	31

I. Tổng quan

1.1 Khái niệm DNS và vai trò của nó

DNS (Domain Name System) là hệ thống phân giải tên miền – chuyển đổi từ tên miền dễ nhớ (vd: facebook.com) sang địa chỉ IP (vd: 157.240.20.35) để máy tính hiểu và kết nối.

- Mỗi khi người dùng gõ một URL, trình duyệt sẽ gửi yêu cầu đến máy chủ DNS để tìm địa chỉ IP tương ứng.
- Quá trình này gọi là DNS Resolution.

Ví dụ thực tế:

- Bạn gõ www.vietcombank.com.vn vào trình duyệt.
- Trình duyệt hỏi máy chủ DNS: “Địa chỉ IP của vietcombank.com.vn là gì?”
- Máy chủ DNS trả lời: “Đây là IP: 123.456.789.001”
- Trình duyệt dùng IP này để truy cập website.

1.2 DNS Spoofing là gì?

DNS Spoofing là hình thức tấn công mạng trong đó:

- Kẻ tấn công gửi phản hồi DNS giả mạo, hoặc làm nhiễm độc bộ nhớ cache DNS (gọi là DNS cache poisoning).
- Người dùng bị lừa truy cập vào một IP giả mạo, mặc dù họ gõ đúng địa chỉ tên miền.

1.3 Mục tiêu của DNS Spoofing

1. Lừa đảo đánh cắp thông tin (Phishing): Điều hướng người dùng đến trang giả lập giao diện giống hệt ngân hàng, mạng xã hội, nhằm đánh cắp tài khoản.
2. Phát tán mã độc: Tự động chuyển hướng nạn nhân đến trang chứa mã độc.
3. Tấn công MITM (Man-in-the-Middle): Chèn kẻ tấn công vào giữa kết nối người dùng và máy chủ thật.
4. Giám điệp và theo dõi lưu lượng truy cập.

1.4 Cơ chế hoạt động của DNS Spoofing

Tình huống bình thường:

1. Người dùng nhập tên miền example.com.

2. Trình duyệt gửi yêu cầu tới máy chủ DNS.
3. Máy chủ DNS trả về IP thật: 93.184.216.34.
4. Trình duyệt kết nối đúng website.

Khi bị DNS Spoofing:

1. Người dùng nhập example.com. Kẻ tấn công đã làm độc cache DNS hoặc giả mạo phản hồi.
2. DNS trả về IP giả mạo: 192.168.1.100 (do hacker kiểm soát).
3. Trình duyệt truy cập trang web giả mà người dùng không hề hay biết.

1.5 Biểu hiện khi bị DNS Spoofing

- Truy cập đúng địa chỉ nhưng đến sai website.
- Giao diện website giống thật nhưng có lỗi nhỏ, hoặc HTTPS không hợp lệ.
- Trình duyệt cảnh báo “Trang web không an toàn”.
- Tăng đột biến các quảng cáo hoặc chuyển hướng bất thường.

II. Các hình thức tấn công DNS Spoofing phổ biến

DNS Spoofing (giả mạo DNS) là một hình thức tấn công an ninh mạng, trong đó kẻ tấn công làm giả dữ liệu DNS để chuyển hướng người dùng đến các trang web độc hại hoặc đánh cắp thông tin. Dưới đây là các hình thức tấn công DNS Spoofing phổ biến và cách thức hoạt động của chúng:

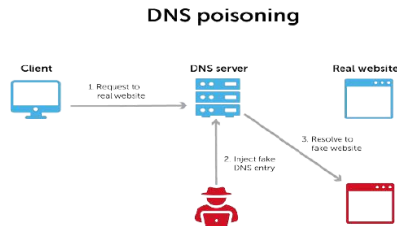
2.1 DNS Cache Poisoning (Nhiễm độc bộ nhớ đệm DNS)

2.1.1 DNS Cacche Poisoning là gì?

DNS Cache Poisoning là một loại tấn công giả mạo DNS, trong đó kẻ tấn công lưu trữ dữ liệu giả trong bộ đệm phân giải DNS. Tất cả các máy khách sử dụng bộ đệm DNS này sau đó nhận được dữ liệu giả và sử dụng nó để kết nối với tài nguyên do kẻ tấn công kiểm soát thay vì tài nguyên hợp pháp.

Đầu độc bộ đệm DNS được coi là một loại tấn công trung gian (MITM) – kẻ tấn công có khả năng không chỉ gửi nạn nhân đến một trang web giả mạo mà còn kết nối đến máy chủ hợp pháp ở chế độ nền và nghe lén thông tin nhạy cảm. Kỹ thuật tương tự có thể được sử dụng cho các cuộc tấn công

lừa đảo rất hiệu quả (thường được gọi là pharming) và để phát tán phần mềm độc hại.



2.1.2 Quá trình ngộ độc bộ nhớ đệm xảy ra như thế nào?

Kẻ tấn công thêm thông tin địa chỉ IP gian lận vào bộ nhớ đệm DNS, do đó khiến trình phân giải DNS gọi trang web độc hại thay vì trang web gốc. Cuộc tấn công này có thể xảy ra vì nhiều lý do. Một là DNS được xây dựng cho một mạng internet nhỏ hơn và không được thiết kế với mục đích bảo mật. Ngoài ra, nó dựa trên nguyên tắc tin cậy vì không có lý do gì để mong đợi hoặc cho rằng bất kỳ ai sẽ cố gắng phát tán thông tin DNS sai, càng không chuyển hướng người dùng đến các trang web độc hại. Do những điểm yếu cố hữu và lâu đời này, kẻ tấn công có thể dễ dàng chiếm đoạt chức năng tra cứu DNS cho mục đích xấu, chẳng hạn như đầu độc bộ đệm DNS.

Ngoài ra, máy chủ DNS sử dụng Giao thức dữ liệu người dùng (UDP) thay vì Giao thức điều khiển truyền (TCP). Thông thường, khi máy chủ sử dụng TCP, nó yêu cầu các bên giao tiếp thực hiện bắt tay, vừa để bắt đầu giao tiếp hai chiều vừa để xác minh danh tính của các thiết bị liên quan đến giao tiếp. UDP không sử dụng cơ chế bắt tay như vậy, vì vậy không có gì đảm bảo người gửi là người mà họ nói.

Lỗi hỏng này cho phép kẻ tấn công làm hỏng bộ đệm DNS.

2.1.3 Tại sao việc đầu độc bộ nhớ đệm DNS lại nguy hiểm?

Đầu độc bộ đệm DNS là một loại tấn công pharming trong đó mã độc được cài đặt trên thiết bị. Vì URL là hợp lệ nên người dùng nghĩ rằng họ đang ở trên một trang web hợp lệ.

Trình duyệt tự động giải quyết địa chỉ tên miền mà không cần bất kỳ sự can thiệp nào của người dùng, do đó người dùng không có lý do gì để nghi ngờ. Đây là một lý do tại sao đầu độc bộ đệm DNS lại là một loại tấn công mạng lén lút như vậy.

Hơn nữa, nếu kẻ tấn công thành công trong việc chen một mục giả duy nhất vào máy chủ lưu trữ đệm -- nghĩa là máy chủ đã chấp nhận bản ghi giả -- hàng trăm hoặc hàng nghìn người dùng có thể được chuyển hướng đến trang web lừa đảo của kẻ tấn công. Nếu tên miền mà người dùng yêu cầu ban đầu đã phổ biến, thì một cuộc tấn công như vậy có thể được thực hiện trên quy mô lớn để thực hiện những điều sau:

- cài đặt phần mềm độc hại vào máy tính của người dùng;
- đánh cắp dữ liệu người dùng, bao gồm thông tin cá nhân hoặc tài chính;...
- đánh cắp thông tin đăng nhập của người dùng, như mật khẩu.

2.1.4 Rủi ro liên quan đến việc đầu độc bộ đệm DNS

Sau đây là một số rủi ro liên quan đến việc đầu độc bộ đệm DNS:

- Nhiễm phần mềm độc hại. Nhiễm độc bộ đệm DNS chuyển hướng người truy cập đến một trang web lừa đảo, cho phép kẻ tấn công cài đặt phần mềm độc hại vào hệ thống của người dùng, ví dụ, thông qua việc tải xuống tự động, có thể cài đặt phần mềm độc hại ngay cả khi người dùng không nhấp vào liên kết, tải xuống bất kỳ thứ gì hoặc mở tệp đính kèm email độc hại.
- Trộm cắp dữ liệu. Chuyển hướng đến một trang web lừa đảo không xác định cũng có thể dẫn đến việc dữ liệu cá nhân của người dùng bị xâm phạm, như mật khẩu và thông tin thẻ tín dụng. Người dùng thậm chí có thể không nhận ra thông tin của họ đã bị xâm phạm.
- Cản trở các bản cập nhật bảo mật. Việc đầu độc bộ nhớ đệm có thể cản trở hoặc dừng các bản cập nhật bảo mật quan trọng, khiến hệ thống của người dùng dễ bị nhiễm vi-rút hoặc Trojan có hại.

2.1.5 Các cách để ngăn chặn DNS Cache Poisoning

➤ Triển khai tiện ích mở rộng bảo mật DNS

DNSSEC (DNS Security Extensions) cung cấp một lớp bảo mật cho DNS. Nó sử dụng chữ ký số để xác minh tính xác thực của dữ liệu phản hồi. Việc

triển khai DNSSEC có thể ngăn chặn kẻ tấn công chen thông tin giả mạo vào bộ đệm DNS.

DNSSEC đảm bảo người dùng được chuyển hướng đến đúng địa chỉ IP, bảo vệ họ khỏi các chuyển hướng độc hại. Tuy nhiên, cần có một số nỗ lực từ chủ sở hữu tên miền và ISP để triển khai.

➤ Sử dụng mã hóa đầu cuối

Mã hóa đầu cuối, có thể được triển khai thông qua giao thức HTTPS, bảo mật thông tin liên lạc giữa người dùng và trang web. Bằng cách mã hóa dữ liệu, nó ngăn chặn kẻ tấn công chặn hoặc thay đổi thông tin, bao gồm cả truy vấn và phản hồi DNS.

Mã hóa khiến kẻ tấn công khó thực hiện đầu độc bộ đệm DNS hơn đáng kể. Tuy nhiên, người dùng và trang web phải hỗ trợ mã hóa để nó có hiệu quả, làm nổi bật tầm quan trọng của việc áp dụng HTTPS.

➤ Triển khai các công cụ phát hiện giả mạo DNS

Triển khai các công cụ phát hiện giả mạo DNS là một phương pháp hiệu quả để xác định và giảm thiểu các cuộc tấn công đầu độc bộ đệm DNS. Các công cụ này giám sát lưu lượng DNS để tìm các mẫu đáng ngờ, chẳng hạn như phản hồi nhanh bất thường hoặc phản hồi từ các địa chỉ IP không mong muốn. Bằng cách phân tích các truy vấn và phản hồi DNS theo thời gian thực, các công cụ này có thể phát hiện các bất thường cho thấy nỗ lực đầu độc.

Hơn nữa, các công cụ phát hiện giả mạo DNS có thể được tích hợp với các hệ thống bảo mật khác, chẳng hạn như hệ thống phát hiện xâm nhập (IDS) và hệ thống quản lý sự kiện và thông tin bảo mật (SIEM). Bằng cách liên kết dữ liệu từ nhiều nguồn khác nhau, các tổ chức có thể hiểu rõ hơn về các kiểu tấn công và tăng cường khả năng phòng thủ chống lại việc đầu độc bộ đệm DNS.

2.2 Man-in-the-Middle DNS Attack (Tấn công trung gian DNS)

2.2.1 Man-in-the-Middle DNS Attack là gì?

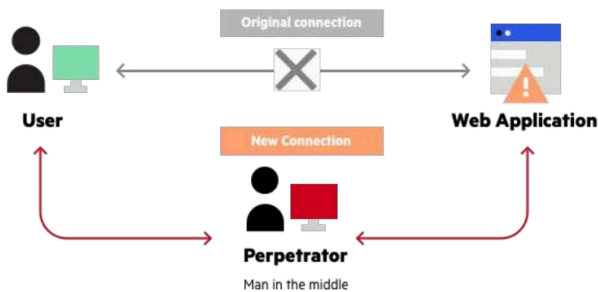
Tấn công kiểu người ở giữa (MITM) là thuật ngữ chung dùng để chỉ trường hợp kẻ tấn công đứng giữa cuộc trò chuyện giữa người dùng và ứng dụng để nghe lén hoặc mạo danh một trong các bên, khiến cuộc trò chuyện trở nên giống như đang diễn ra trao đổi thông tin bình thường.

Mục tiêu của cuộc tấn công là đánh cắp thông tin cá nhân, chẳng hạn như thông tin đăng nhập, thông tin chi tiết về tài khoản và số thẻ tín dụng. Mục tiêu thường là người dùng các ứng dụng tài chính, doanh nghiệp SaaS, trang web thương mại điện tử và các trang web khác yêu cầu đăng nhập.

Thông tin thu thập được trong cuộc tấn công có thể được sử dụng cho nhiều mục đích, bao gồm đánh cắp danh tính, chuyển tiền trái phép hoặc thay đổi mật khẩu trái phép.

Ngoài ra, nó có thể được sử dụng để giành được chỗ đứng bên trong chu vi an toàn trong giai đoạn xâm nhập của cuộc tấn công đe dọa dai dẳng nâng cao (APT).

Nói chung, một cuộc tấn công MITM tương đương với việc một người đưa thư mở sáo kê ngân hàng của bạn, ghi lại thông tin tài khoản rồi dán lại phong bì và giao đến tận nhà bạn.



2.2.2 Tiến trình tấn công MITM

Việc thực hiện thành công MITM có 2 giai đoạn: Chặn và giải mã.

➤ Chặn

Bước đầu tiên là chặn lưu lượng truy cập của người dùng qua mạng của kẻ tấn công trước khi nó đến đích dự định.

Cách phổ biến nhất (và đơn giản nhất) để thực hiện điều này là một cuộc tấn công thụ động trong đó kẻ tấn công tạo ra các điểm truy cập WiFi miễn phí, độc hại cho công chúng. Thông thường được đặt tên theo cách tương ứng với vị trí của chúng, chúng không được bảo vệ bằng mật khẩu. Khi nạn nhân kết nối với điểm truy cập như vậy, kẻ tấn công sẽ có được khả năng hiển thị đầy đủ đối với bất kỳ trao đổi dữ liệu trực tuyến nào.

Kẻ tấn công muốn áp dụng biện pháp chủ động hơn để chặn có thể thực hiện một trong các cuộc tấn công sau:

- Giả mạo IP liên quan đến việc kẻ tấn công nguy trang thành một ứng dụng bằng cách thay đổi tiêu đề gói tin trong địa chỉ IP. Kết quả là, người dùng cố gắng truy cập URL được kết nối với ứng dụng sẽ được chuyển đến trang web của kẻ tấn công.
- Giả mạo ARP là quá trình liên kết địa chỉ MAC của kẻ tấn công với địa chỉ IP của người dùng hợp pháp trên mạng cục bộ bằng cách sử dụng tin nhắn ARP giả. Kết quả là, dữ liệu do người dùng gửi đến địa chỉ IP của máy chủ thay vào đó được truyền đến kẻ tấn công.
- DNS spoofing, còn được gọi là DNS cache poisoning, bao gồm việc xâm nhập vào máy chủ DNS và thay đổi bản ghi địa chỉ của trang web. Kết quả là, người dùng cố gắng truy cập trang web sẽ được chuyển đến trang web của kẻ tấn công thông qua bản ghi DNS đã thay đổi.

➤ Giải mã

Sau khi chặn, bất kì lưu lượng SSL hai chiều nào cũng cần được giải mã mà không cần cảnh báo người dùng hoặc ứng dụng. Có một số phương pháp để đạt được điều này:

- Giả mạo HTTPS gửi một chứng chỉ giả đến trình duyệt của nạn nhân sau khi yêu cầu kết nối ban đầu đến một trang web an toàn được thực hiện. Nó giữ một dấu vân tay kỹ thuật số liên quan đến ứng dụng bị xâm phạm, trình duyệt sẽ xác minh theo danh sách các trang web đáng tin cậy hiện có. Sau đó, kẻ tấn công có thể truy cập bất kỳ dữ liệu nào do nạn nhân nhập trước khi dữ liệu đó được chuyển đến ứng dụng.
- SSL BEAST (lỗ hổng trình duyệt chống lại SSL/TLS) nhắm vào lỗ hổng TLS phiên bản 1.0 trong SSL. Ở đây, máy tính của nạn nhân bị nhiễm JavaScript độc hại chặn cookie được mã hóa do ứng dụng web gửi. Sau đó, chuỗi khối mã hóa (CBC) của ứng dụng bị xâm phạm để giải mã cookie và mã thông báo xác thực của ứng dụng.
- Việc tấn công SSL xảy ra khi kẻ tấn công chuyển khóa xác thực giả mạo cho cả người dùng và ứng dụng trong quá trình bắt tay TCP.

Điều này thiết lập kết nối có vẻ an toàn khi trên thực tế, người ở giữa kiểm soát toàn bộ phiên.

- Tước SSL hạ cấp kết nối HTTPS xuống HTTP bằng cách chặn xác thực TLS được gửi từ ứng dụng đến người dùng. Kẻ tấn công gửi phiên bản không được mã hóa của trang web ứng dụng đến người dùng trong khi vẫn duy trì phiên bảo mật với ứng dụng. Trong khi đó, toàn bộ phiên của người dùng đều hiển thị với kẻ tấn công.

2.2.3 Các hình thức tấn công Man-in-the-Middle

Dưới đây là những hình thức tấn công Man-in-the-middle phổ biến hiện nay:

- **IP Spoofing (giả mạo địa chỉ IP):** Kẻ tấn công sẽ giả mạo địa chỉ IP của nạn nhân, sau đó thay thế nạn nhân để giao tiếp với đối phương. Lúc này, kẻ tấn công có thể đánh cắp toàn bộ thông tin và dữ liệu đang trao đổi.
- **DNS spoofing (giả mạo DNS):** Kẻ tấn công sẽ thay đổi địa chỉ website trên máy chủ DNS, khiến nạn nhân truy cập vào website giả mạo. Mục tiêu của hình thức này là thủ phạm cần tăng lượng truy cập cho website giả mạo hoặc đánh cắp thông tin đăng nhập của nạn nhân.
- **HTTPS spoofing (giả mạo HTTPS):** Kẻ tấn công sẽ tạo ra một kết nối HTTPS giả mạo để khiến nạn nhân nghĩ rằng họ đang kết nối với một trang web an toàn. Tuy nhiên, kết nối này thực chất không được mã hóa an toàn, kẻ tấn công sẽ theo dõi tương tác của nạn nhân ở trên website và đánh cắp các thông tin được chia sẻ.
- **SSL Hijacking (đánh cắp SSL):** Kẻ tấn công chặn các kết nối SSL giữa máy chủ và máy khách, sau đó mã hoá dữ liệu để đánh cắp thông tin.
- **Email Hijacking (đánh cắp email):** Kẻ tấn công sẽ giả mạo hoặc xâm nhập vào tài khoản email của các tổ chức, đặc biệt là tổ chức tài chính. Sau đó, gửi email cho nạn nhân, lừa nạn nhân cung cấp các thông tin quan trọng.
- **WiFi Eavesdropping (nghe lén Wifi):** Kẻ tấn công sẽ thiết lập một điểm truy cập Wifi giả mạo để lừa người dùng kết nối. Sau đó, chặn và đánh cắp tất cả dữ liệu được truyền đi thông qua mạng Wifi ảo. Hình thức tấn công MitM này thường xảy ra ở những điểm Wifi miễn phí hoặc Wifi công cộng, khi kẻ tấn công truy cập được bộ định tuyến Wifi.

- **Stealing Browser Cookies (Ăn cắp trình duyệt cookie):** Kẻ tấn công sẽ đánh cắp cookie của trình duyệt - nơi lưu trữ thông tin các phiên trình duyệt của nạn nhân. Thông qua đó, truy cập vào các tài khoản trực tiếp của nạn nhân mà không cần mật khẩu hoặc đánh cắp những thông tin quan trọng khác.

2.2.4 Phòng ngừa tấn công

Việc chặn các cuộc tấn công MITM đòi hỏi người dùng phải thực hiện một số bước thực tế cũng như kết hợp các phương pháp mã hóa và xác minh cho các ứng dụng.

Đối với người dùng, điều này có nghĩa là:

- Tránh kết nối WiFi không được bảo vệ bằng mật khẩu.
- Chú ý đến các thông báo của trình duyệt báo cáo rằng một trang web không an toàn.
- Đăng xuất ngay khỏi ứng dụng an toàn khi không sử dụng.
- Không sử dụng mạng công cộng (ví dụ: quán cà phê, khách sạn) khi thực hiện các giao dịch nhạy cảm.

Đối với người vận hành trang web, các giao thức truyền thông an toàn, bao gồm TLS và HTTPS, giúp giảm thiểu các cuộc tấn công giả mạo bằng cách mã hóa và xác thực dữ liệu được truyền đi một cách mạnh mẽ. Làm như vậy sẽ ngăn chặn việc chặn lưu lượng truy cập trang web và chặn việc giải mã dữ liệu nhạy cảm, chẳng hạn như mã thông báo xác thực.

2.3 DNS Hijacking (Chiếm quyền điều khiển DNS)

2.3.1 DNS Hijacking là gì?

Domain Name Server (DNS) hijacking, còn được gọi là DNS redirection, là một loại tấn công DNS trong đó các truy vấn DNS được giải quyết không chính xác để bắt ngờ chuyển hướng người dùng đến các trang web độc hại. Để thực hiện cuộc tấn công, thủ phạm cài đặt phần mềm độc hại trên máy tính của người dùng, chiếm quyền điều khiển bộ định tuyến hoặc chặn hoặc hack giao tiếp DNS.

Việc chiếm quyền điều khiển DNS có thể được sử dụng để lừa đảo (trong bối cảnh này, kẻ tấn công thường hiển thị các quảng cáo không mong muốn để tạo doanh thu) hoặc để lừa đảo (hiển thị các phiên bản giả mạo của các

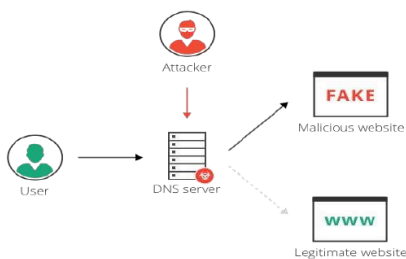
trang web mà người dùng truy cập và đánh cắp dữ liệu hoặc thông tin đăng nhập).

Nhiều Nhà cung cấp dịch vụ Internet (ISP) cũng sử dụng một loại DNS hijacking, để tiếp quản các yêu cầu DNS của người dùng, thu thập số liệu thống kê và trả về quảng cáo khi người dùng truy cập vào một tên miền không xác định. Một số chính phủ sử dụng DNS hijacking để kiểm duyệt, chuyển hướng người dùng đến các trang web được chính phủ cho phép.

2.3.2 Các loại tấn công chiếm quyền điều khiển DNS

Có bốn loại chuyển hướng DNS cơ bản:

- Trộm DNS cục bộ — kẻ tấn công cài đặt phần mềm độc hại Trojan vào máy tính của người dùng và thay đổi cài đặt DNS cục bộ để chuyển hướng người dùng đến các trang web độc hại.
- Router DNS hijack — nhiều router có mật khẩu mặc định hoặc lỗ hổng phần mềm. Kẻ tấn công có thể chiếm quyền điều khiển router và ghi đè cài đặt DNS, ảnh hưởng đến tất cả người dùng được kết nối với router đó.
- Tấn công DNS kiểu trung gian — kẻ tấn công chặn giao tiếp giữa người dùng và máy chủ DNS và cung cấp các địa chỉ IP đích khác nhau trở đến các trang web độc hại.
- Máy chủ DNS giả mạo — kẻ tấn công có thể hack máy chủ DNS và thay đổi bản ghi DNS để chuyển hướng các yêu cầu DNS đến các trang web độc hại.



2.3.3 Cách phát hiện DNS Hijacking

Tin vui là có nhiều cách đơn giản để phát hiện liệu DNS của bạn đã bị hack hay chưa. Đầu tiên, bạn cần quan sát xem những website mình thường truy cập có biểu hiện chậm hơn thông thường hay không, hoặc bạn có ngẫu nhiên nhận được quảng cáo dạng popup (với nội dung rằng máy tính của bạn bị nhiễm virus chẳng hạn) - nếu có, DNS của bạn nhiều khả năng đã bị hack. Tuy nhiên, với những triệu chứng trên, chưa thể khẳng định chắc chắn điều gì. Do đó, dưới đây là một vài cách test hiệu quả mà bạn có thể thực hiện:

- Chạy câu lệnh “ping”
- Câu lệnh “ping” chủ yếu được sử dụng để kiểm tra một địa chỉ IP có thực sự tồn tại hay không. Nếu trình duyệt của bạn “ping” đến một địa chỉ IP không tồn tại mà vẫn phân giải được, thì khả năng cao DNS của bạn đã bị hack.
- Trên macOS, bạn mở ứng dụng “Terminal” và gõ câu lệnh sau: ping kaspersky123456.com
- Nếu kết quả trả về là “cannot resolve” thì DNS vẫn ổn.
- Trên Windows, mở “Command Prompt” và gõ: ping kaspersky123456.com
- Nếu kết quả trả về là “cannot resolve”, bạn không có gì phải lo lắng.
- Kiểm tra router hoặc sử dụng một ứng dụng kiểm tra router
- Bước tiếp theo là sử dụng các website trực tuyến để kiểm tra router. Các dịch vụ này hoạt động bằng cách kiểm tra hệ thống với một DNS resolver đáng tin cậy, và xem liệu bạn có đang sử dụng một máy chủ DNS đã được ủy quyền hay chưa. Bên cạnh đó, bạn cũng có thể vào trang admin của router để kiểm tra các thiết lập tại đó.
- Sử dụng WhoIsMyDNS.com
- Dịch vụ này cho biết các máy chủ DNS mà bạn đang sử dụng và công ty sở hữu chúng. Trình duyệt của bạn sẽ sử dụng địa chỉ IP của các máy chủ DNS do ISP của bạn cung cấp. Nếu tên công ty có vẻ lạ, thì bạn đã bị DNS hijacking.
- Nếu biết máy chủ DNS của bạn đã bị hack, hoặc từng diễn ra trước đây, thì lời khuyên là sử dụng một dịch vụ DNS công cộng, như Google DNS.

2.3.4 Phương pháp giảm thiểu

➤ Giảm thiểu cho máy chủ tên và trình phân giải

Máy chủ tên DNS là cơ sở hạ tầng cực kỳ nhạy cảm, đòi hỏi các biện pháp bảo mật mạnh mẽ vì nó có thể bị tin tặc chiếm đoạt và sử dụng để thực hiện các cuộc tấn công DDoS vào các máy chủ khác:

- Hãy chú ý đến các bộ giải quyết trên mạng của bạn — các bộ giải quyết DNS không cần thiết nên được tắt. Các bộ giải quyết hợp lệ nên được đặt sau tường lửa mà không có quyền truy cập từ bên ngoài tổ chức.
- Hạn chế nghiêm ngặt quyền truy cập vào máy chủ tên — cần sử dụng cả biện pháp bảo mật vật lý, truy cập đa yếu tố, tường lửa và bảo mật mạng.
- Thực hiện các biện pháp chống đầu độc bộ nhớ đệm — sử dụng cổng nguồn ngẫu nhiên, ngẫu nhiên hóa ID truy vấn và ngẫu nhiên hóa chữ hoa/thường trong tên miền.
- Vá ngay các lỗ hổng đã biết — tin tặc đang tích cực tìm kiếm các máy chủ DNS để bị tấn công.
- Tách riêng máy chủ tên có thẩm quyền khỏi trình phân giải — không chạy cả hai trên cùng một máy chủ, do đó, một cuộc tấn công DDoS vào bất kỳ thành phần nào cũng sẽ không phá hủy được thành phần còn lại.
- Hạn chế chuyển vùng — máy chủ tên phụ có thể yêu cầu chuyển vùng, tức là sao chép một phần bản ghi DNS của bạn. Bản ghi vùng chứa thông tin có giá trị đối với kẻ tấn công.

➤ Giảm thiểu cho người dùng cuối

Người dùng cuối có thể tự bảo vệ mình khỏi việc chiếm đoạt DNS bằng cách thay đổi mật khẩu bộ định tuyến, cài đặt phần mềm diệt vi-rút và sử dụng kênh VPN được mã hóa. Nếu ISP của người dùng đang chiếm đoạt DNS của họ, họ có thể sử dụng dịch vụ DNS thay thế miễn phí như Google Public DNS, Google DNS qua HTTPS và Cisco OpenDNS.

➤ Giảm thiểu cho chủ sở hữu trang web

Chủ sở hữu trang web sử dụng Nhà đăng ký tên miền có thể thực hiện các bước để tránh chuyển hướng DNS của bản ghi DNS của họ:

- Truy cập an toàn — sử dụng xác thực hai yếu tố khi truy cập vào cơ quan đăng ký DNS để tránh bị xâm phạm. Nếu có thể, hãy xác định danh sách trắng các địa chỉ IP được phép truy cập vào cài đặt DNS.
- Khóa máy khách — kiểm tra xem cơ quan đăng ký DNS của bạn có hỗ trợ khóa máy khách (còn gọi là khóa thay đổi) hay không, tính năng này ngăn chặn việc thay đổi bản ghi DNS của bạn mà không có sự chấp thuận từ một cá nhân cụ thể.

2.4 Pharming Attack (Tấn công chuyển hướng DNS)

2.4.1 Pharming Attack là gì?

Pharming là thuật ngữ dùng để mô tả một loại tấn công mạng chuyển hướng người dùng đến các trang web lừa đảo hoặc thao túng hệ thống máy tính của họ để thu thập thông tin nhạy cảm. Còn được gọi là "lừa đảo được phẩm" hoặc "lừa đảo không cần mồi nhử", "pharming" là sự kết hợp của các từ "lừa đảo" và "trồng trọt", cho thấy bản chất quy mô lớn của cuộc tấn công.

Trong các cuộc tấn công pharming, các cá nhân hoặc nhóm độc hại sử dụng nhiều kỹ thuật khác nhau để lừa người dùng và dẫn họ đến các trang web giả mạo trông rất giống với các trang web hợp pháp, chẳng hạn như cổng thông tin ngân hàng trực tuyến, nền tảng mua sắm bán lẻ hoặc mạng xã hội. Mục đích cuối cùng đằng sau các cuộc tấn công như vậy là lừa người dùng tiết lộ thông tin cá nhân của họ, chẳng hạn như tên người dùng, mật khẩu, thông tin chi tiết về thẻ tín dụng hoặc dữ liệu nhạy cảm khác.

Pharming giống như lừa đảo trực tuyến ở chỗ nó là mối đe dọa lừa người dùng tiết lộ thông tin riêng tư, nhưng thay vì dựa vào email làm vector tấn công, pharming sử dụng mã độc được thực thi trên thiết bị của nạn nhân để chuyển hướng đến trang web do kẻ tấn công kiểm soát. Vì pharming chạy mã trên máy tính của nạn nhân, kẻ tấn công không dựa vào người dùng mục tiêu nhấp vào liên kết hoặc trả lời email. Thay vào đó, mã độc sẽ chuyển hướng người dùng mục tiêu đến trang web của kẻ tấn công, loại bỏ bước bổ sung là người dùng nhấp vào liên kết.

2.4.2 Cách Pharming hoạt động

Pharming là một loại hoạt động gian lận tinh vi chuyển hướng người dùng internet đến các trang web giả mạo để đánh cắp thông tin cá nhân hoặc tài

chính, chẳng hạn như thông tin đăng nhập, chi tiết thẻ tín dụng hoặc số an sinh xã hội. Mặc dù pharming có thể có nhiều hình thức, nhưng nhìn chung nó được thực hiện bằng một trong các kỹ thuật sau:

- **Nhiễm phần mềm độc hại:** Phần mềm độc hại như vi-rút máy tính, Trojan hoặc keylogger có thể được sử dụng để thực hiện các cuộc tấn công pharming. Các chương trình độc hại này có thể lấy nhiễm máy tính hoặc mạng của người dùng, thay đổi cài đặt DNS hoặc thao túng tệp của máy chủ. Khi người dùng cố gắng truy cập một trang web hợp pháp, họ vô tình bị chuyển hướng đến một trang web độc hại.
- **Đầu độc bộ đệm DNS:** Khai thác lỗ hổng trong Hệ thống tên miền (DNS) là một cách khác mà kẻ tấn công mạng thực hiện pharming. DNS chịu trách nhiệm dịch tên miền thành địa chỉ IP mà máy tính có thể hiểu được. Bằng cách đầu độc bộ đệm DNS, kẻ tấn công có thể thao túng ánh xạ giữa tên miền và địa chỉ IP.
- **Sửa đổi tệp máy chủ:** Một kỹ thuật khác liên quan đến việc thay đổi tệp máy chủ trên máy tính của người dùng hoặc cấu hình DNS trên mạng cục bộ. Tệp máy chủ là tệp cục bộ trên máy tính ánh xạ tên miền đến các địa chỉ IP cụ thể. Kẻ tấn công có thể sửa đổi tệp này để chuyển hướng người dùng đến các trang web độc hại thay vì các trang web hợp pháp.
- **Máy chủ DNS giả mạo:** Kẻ tấn công có thể thiết lập máy chủ DNS giả mạo hoặc xâm phạm máy chủ DNS hiện có. Khi người dùng cố gắng truy cập một trang web hợp pháp, yêu cầu của họ sẽ được chuyển hướng đến các máy chủ DNS độc hại này. Sau đó, máy chủ cung cấp địa chỉ IP giả, dẫn người dùng đến các trang web gian lận bất chước phiên bản thực.

Khi người dùng được chuyển hướng đến các trang web lừa đảo, họ thường được nhắc gửi thông tin nhạy cảm mà kẻ tấn công sau đó sẽ nắm bắt. Kẻ tấn công khai thác thông tin này cho nhiều mục đích độc hại khác nhau, chẳng hạn như đánh cắp danh tính, gian lận tài chính hoặc truy cập tài khoản trái phép.

2.4.3 Các loại Pharming

Có hai loại tấn công pharming chính: pharming dựa trên DNS và pharming dựa trên máy chủ. Trong mỗi loại có các phương pháp cụ thể mà kẻ tấn công sử dụng. Chúng ta hãy xem xét kỹ hơn từng loại:

➤ Pharming dựa trên DNS

Các cuộc tấn công pharming dựa trên DNS khai thác lỗ hổng trong cơ sở hạ tầng DNS để chuyển hướng người dùng đến các trang web độc hại. Loại tấn công này thường bao gồm các phương pháp sau:

- **Đầu độc bộ đệm DNS:** Kẻ tấn công thao túng bộ đệm DNS của máy chủ DNS hoặc bộ định tuyến để chuyển hướng ánh xạ tên miền sang địa chỉ IP. Bằng cách đưa các bản ghi DNS sai vào bộ đệm, chúng có thể chuyển hướng người dùng đến các trang web gian lận.
- **Xâm phạm máy chủ DNS:** Khi truy cập trái phép vào máy chủ DNS, kẻ tấn công sẽ sửa đổi cài đặt DNS để thay đổi địa chỉ IP được liên kết với tên miền, do đó chuyển hướng người dùng đến một trang web độc hại.
- **DNS Hijacking:** Kẻ tấn công xâm phạm cài đặt DNS trên máy tính hoặc bộ định tuyến của người dùng để chuyển hướng yêu cầu DNS của họ đến các máy chủ DNS độc hại. Các máy chủ này cung cấp địa chỉ IP giả, dẫn người dùng đến các trang web lừa đảo.
- **Pharming thông tin xác thực:** Còn được gọi là thu thập thông tin xác thực hoặc đánh cắp thông tin đăng nhập, loại tấn công pharming này đánh cắp thông tin đăng nhập của người dùng bằng cách thao túng cài đặt DNS và tệp lưu trữ hoặc bằng cách sử dụng các kỹ thuật khác để chuyển hướng người dùng đến các trang web giả mạo bắt chước các trang web hợp pháp.

➤ Pharming dựa trên máy chủ

Loại tấn công pharming này liên quan đến việc thao túng tệp tin của máy chủ trên máy tính của người dùng hoặc cấu hình DNS trên mạng cục bộ thông qua các phương pháp sau:

- **Sửa đổi tệp máy chủ cục bộ:** Khi kẻ tấn công sửa đổi tệp máy chủ trên máy tính của nạn nhân, chúng có thể chuyển hướng yêu cầu của người dùng từ các trang web hợp pháp sang các địa chỉ IP độc hại. Thao túng cấu hình DNS của bộ định tuyến: Kẻ tấn công có thể nhắm mục tiêu vào cài đặt DNS trên bộ định tuyến của mạng cục bộ.

Khi người dùng kết nối với mạng, yêu cầu DNS của họ sẽ chuyển hướng đến máy chủ DNS độc hại trở đến các trang web giả mạo.

- **Malware Pharming:** Kẻ tấn công có thể sử dụng phần mềm độc hại như vi-rút máy tính, Trojan hoặc keylogger để lây nhiễm máy tính hoặc mạng của người dùng. Phần mềm độc hại này sửa đổi cài đặt DNS hoặc tệp máy chủ, chuyển hướng người dùng đến các trang web độc hại.

Các loại tấn công pharming khác nhau có thể được kết hợp với các kỹ thuật kỹ thuật xã hội khác, chẳng hạn như email lừa đảo hoặc thiết kế trang web lừa đảo, để tăng hiệu quả của chúng. Bằng cách dẫn dắt người dùng không biết đến các trang web lừa đảo, kẻ tấn công tăng cơ hội đánh cắp thông tin.

2.4.4 Dấu hiệu của một cuộc tấn công Pharming

Việc phát hiện các cuộc tấn công pharming ngày càng trở nên khó khăn hơn vì chúng ngày càng trở nên lừa dối người dùng. Tuy nhiên, một số dấu hiệu có thể chỉ ra một cuộc tấn công pharming có thể xảy ra:

- Hành vi bất thường hoặc những thay đổi bất ngờ khi truy cập một trang web quen thuộc, chẳng hạn như bố cục khác, logo bị mất hoặc bị thay đổi hoặc lời nhắc đáng ngờ yêu cầu cung cấp thông tin cá nhân.
- Nhận được email hoặc tin nhắn văn bản không mong muốn có chứa liên kết đến một trang web.
- Cửa sổ bật lên hoặc cảnh báo yêu cầu bạn nhập thông tin cá nhân.
- Địa chỉ web hoặc URL không chính xác trên thanh trình duyệt, trông khác với những gì bạn mong đợi hoặc bao gồm các ký tự bất thường, tên miền phụ bổ sung hoặc lỗi chính tả.
- Trình duyệt web chuyển hướng bạn đến một trang web hoặc URL khác với trang web hoặc URL bạn định truy cập.
- Lỗi hoặc cảnh báo về chứng chỉ SSL xuất hiện khi truy cập vào một trang web trước đó có chứng chỉ SSL hợp lệ mà không có lỗi hoặc cảnh báo như vậy.
- Sự cố kết nối mạng hoặc internet đột ngột có thể chỉ ra cài đặt DNS bị xâm phạm.
- Các hoạt động tài khoản bất thường, chẳng hạn như giao dịch tài chính, mà bạn không khởi tạo.

2.4.5 Làm thế nào để ngăn ngừa Pharming

Để tránh trở thành nạn nhân của pharming, các bước và biện pháp thực hành tốt nhất tương tự như ngăn chặn vi-rút và phần mềm độc hại cục bộ khác. Luôn nghi ngờ các email có tệp đính kèm, đặc biệt là các tệp thực thi. Các tệp có chứa macro, chẳng hạn như Microsoft Word hoặc Excel, cũng có thể chạy mã độc. Bạn nên chặn macro trừ khi bạn biết tệp đó đến từ một nguồn đáng tin cậy.

Một số biện pháp tốt nhất bổ sung để ngăn bạn trở thành nạn nhân bao gồm:

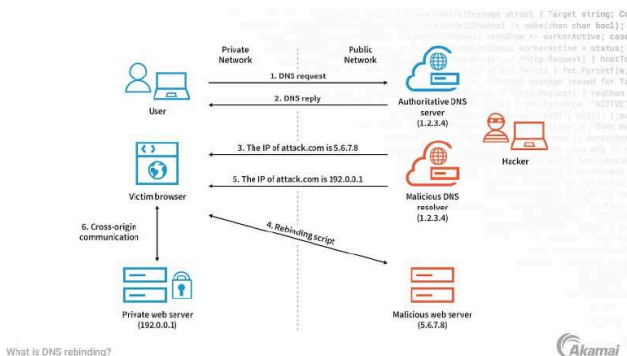
- Sử dụng dịch vụ DNS an toàn để bảo vệ máy chủ DNS khỏi bị đầu độc, một phương pháp thường được sử dụng trong các cuộc tấn công pharming.
 - Hãy cập nhật hệ thống của bạn bằng các bản vá bảo mật mới nhất. Các cuộc tấn công Pharming dựa vào các lỗ hổng đã biết trong phần mềm, do đó, việc cập nhật phần mềm của bạn có thể giúp ngăn chặn các cuộc tấn công này.
 - Hãy thận trọng khi nhập thông tin cá nhân trực tuyến. Đảm bảo bạn đang ở trên một trang web hợp pháp, an toàn trước khi gửi bất kỳ thông tin nhạy cảm nào, chẳng hạn như thông tin đăng nhập hoặc dữ liệu tài chính.
 - Kiểm tra kỹ URL trang web trước khi nhấp vào bất kỳ liên kết nào hoặc nhập thông tin của bạn. Tìm HTTPS trong URL và đảm bảo địa chỉ trang web khớp với trang web hợp lệ.
 - Sử dụng xác thực hai yếu tố hoặc đa yếu tố bất cứ khi nào có thể để tăng thêm một lớp bảo mật cho tài khoản của bạn.
 - Bảo mật mạng Wi-Fi tại nhà hoặc văn phòng của bạn bằng cách thay đổi mật khẩu quản trị viên mặc định trên bộ định tuyến, bật mã hóa (như WPA2) cho mạng Wi-Fi và thường xuyên kiểm tra các bản cập nhật chương trình cơ sở.
 - Tránh kết nối với các mạng Wi-Fi công cộng tùy ý hoặc các điểm truy cập không xác định, ngay cả khi chỉ lướt Internet.

- Sử dụng phần mềm diệt vi-rút đáng tin cậy và dịch vụ VPN (hoặc giải pháp thay thế VPN) để bảo vệ bạn khỏi phần mềm độc hại và bảo vệ quyền riêng tư trực tuyến.

2.5 Tấn công DNS Rebinding

2.5.1 Tấn công DNS Rebinding là gì?

DNS rebinding là một loại tấn công mạng tận dụng Hệ thống tên miền (DNS) để chạy JavaScript độc hại và tấn công các thiết bị trên mạng riêng của người dùng. Trong một cuộc tấn công DNS rebinding, tin tặc lừa trình duyệt của nạn nhân chạy một tập lệnh phía máy khách tấn công các máy trên mạng riêng của nạn nhân không được kết nối với internet công cộng. Các cuộc tấn công này cũng thiết lập giao tiếp giữa máy chủ của kẻ tấn công và một ứng dụng web trên mạng của nạn nhân, thường là để chạy phần mềm độc hại hoặc tạo điều kiện cho các hành vi độc hại khác.



2.5.2 Cuộc tấn công DNS Rebinding hoạt động như thế nào?

- Đăng ký tên miền – Kẻ tấn công đăng ký tên miền (malicious.com). Sau đó, hắn sẽ sử dụng lừa đảo, phần mềm quảng cáo hoặc các trang web bị xâm phạm để dụ nạn nhân truy cập vào tên miền độc hại.
- Ủy quyền DNS – Tin tặc cấu hình cài đặt DNS cho toxic.com để ủy quyền giải quyết cho máy chủ DNS mà chúng kiểm soát. Do đó, chúng sẽ có thể thao túng phản hồi DNS cho tên miền.

- Giải quyết DNS – Trình duyệt của nạn nhân cố gắng giải quyết tên miền và gửi yêu cầu DNS đến máy chủ DNS chịu trách nhiệm. Thay vào đó, máy chủ DNS độc hại nhận được yêu cầu.
- Lúc đầu, máy chủ độc hại có thể lấy một địa chỉ IP hợp lệ. Theo cách này, nó cố gắng làm cho mọi thứ trông giống như trải nghiệm duyệt web bình thường.
- Thiết lập TTL ngắn – Phản hồi DNS hợp lệ mà máy chủ độc hại thu thập được có giá trị Time-to-Live (TTL) rất ngắn. Các tác nhân đe dọa thiết lập như vậy để tránh phản hồi được lưu trữ đệm bởi trình duyệt của nạn nhân hoặc máy chủ DNS trung gian.
- Phản hồi liên kết lại – Ngay sau đó, máy chủ DNS của tin tặc sẽ gửi phản hồi DNS tiếp theo trở đến một địa chỉ IP khác, dẫn đến máy chủ C&C của chúng.
- Vi phạm – Khi trình duyệt của nạn nhân nhận được địa chỉ IP độc hại và thiết lập giao tiếp với máy chủ C2, máy chủ sẽ phản hồi bằng mã độc được nhúng trong trang web. Sau đó, kẻ tấn công sẽ có thể khai thác lỗ hổng trong trình duyệt hoặc mạng của nạn nhân để bỏ qua Chính sách cùng nguồn gốc (SOP). Đây là lý do tại sao mã độc có thể tương tác với các tài nguyên trên mạng của nạn nhân và truy cập thông tin nhạy cảm.
- Kết quả – Từ đó, kẻ tấn công sẽ có thể thu thập và đánh cắp dữ liệu nhạy cảm từ mạng của nạn nhân hoặc giành quyền kiểm soát các thiết bị hoặc hệ thống dễ bị tấn công.

2.5.3 Rủi ro và lỗ hổng liên kết DNS

Một cuộc tấn công liên kết DNS thành công thường khai thác một loạt lỗ hổng sau:

- Tấn công xuyên trang web—XSS,
- Cài đặt DNS mặc định hoặc không đúng cấu hình,
- Chính sách cùng nguồn gốc (SOP) được triển khai kém cho phép các tập lệnh từ các nguồn gốc khác nhau tương tác với các tài nguyên bị hạn chế,
- Không xác thực tên máy chủ.

Lúc đầu, các tác nhân đe dọa sử dụng DNS rebinding để khai thác các thiết bị IoT dễ bị tấn công, nhưng gần đây, chúng đã sử dụng kỹ thuật này để

tấn công cả mạng công ty. Có hai loại tấn công chính phát sinh từ việc khai thác các lỗi hỏng DNS rebinding.

➤ Vượt tường lửa

Trong trường hợp này, tác nhân đe dọa tận dụng DNS rebinding để truy cập các điểm cuối sau tường lửa. Việc trốn tránh phát hiện của tường lửa cho phép tin tặc có khả năng thu thập Intranet của một tổ chức và do đó có thể truy cập vào các tài liệu nhạy cảm.

Một rủi ro khác là làm hỏng các thiết bị chưa vá. Thiếu thời gian là lý do phổ biến khiến các công ty thường không vá các điểm cuối kịp thời. Đây là lý do tại sao các tổ chức vừa và lớn sử dụng các giải pháp vá tự động để ngăn chặn tin tặc khai thác các lỗ hổng đã biết.

Việc vượt tường lửa cũng cho phép các tác nhân đe dọa lạm dụng các dịch vụ mở nội bộ. Nếu chúng có thể đọc và ghi các socket tùy ý, tin tặc cũng có thể thu thập và đánh cắp dữ liệu từ các tài liệu được chia sẻ nội bộ.

➤ Trộm cắp IP

Các lỗ hổng được sử dụng để truy cập vào máy chủ công cộng từ địa chỉ IP của máy khách. Để cuộc tấn công thành công, trước tiên máy khách phải tải một số nội dung đang hoạt động. Sau đó, mã của tin tặc có thể giao tiếp với bất kỳ thiết bị nào nằm trong phạm vi tiếp cận của máy khách.

Click Fraud không phải là một cuộc tấn công mạng, nhưng nó là một hoạt động bất hợp pháp tận dụng DNS rebinding. Các nhà xuất bản vô đạo đức có thể sử dụng nó để tạo ra các nhấp chuột giả và có được một báo cáo hấp dẫn hơn cho các nhà quảng cáo của họ, ví dụ.

Thông thường, máy chủ email sẽ đưa các địa chỉ IP vào danh sách đen được báo cáo là gửi thư rác. Vì vậy, để tiếp tục chiến dịch lừa đảo qua email, những kẻ xấu sẽ chiếm đoạt địa chỉ IP của khách hàng để tránh bị chặn.

Ngoài ra, những kẻ tấn công có thể sử dụng địa chỉ IP bị chiếm đoạt làm proxy và cố gắng truy cập trái phép vào hệ thống máy tính. Đây là phương pháp hiệu quả để xâm phạm các nỗ lực điều tra pháp y của các tổ chức nạn nhân và không để lại dấu vết. Các nhà phân tích bảo mật sẽ quan sát thấy rằng cuộc tấn công được tạo ra từ địa chỉ IP bị chiếm đoạt. Do đó, nhật ký sẽ chỉ liên quan đến máy khách, không phải tác nhân đe dọa.

2.5.4 Làm thế nào để ngăn chặn cuộc tấn công DNS Rebinding?

Bảo vệ tài sản và mạng của công ty vẫn là một thách thức phức tạp do bối cảnh đe dọa cực kỳ năng động mà các nhóm SOC phải đối mặt. Vì vậy, bảo mật lớp DNS và cấu hình DNS phù hợp là các bước quan trọng cần đưa vào bất kỳ chiến lược phòng thủ nào.

Một số biện pháp tốt nhất để ngăn chặn kẻ xấu sử dụng kỹ thuật liên kết lại DNS chống lại công ty của bạn là:

➤ Ngăn chặn việc vượt tường lửa

Để đạt được điều đó, hãy từ chối phân giải tên máy chủ bên ngoài thành địa chỉ IP nội bộ và thực hiện lọc lưu lượng truy cập.

➤ Triển khai ghim DNS

Kỹ thuật ghim DNS ngăn chặn việc lưu trữ đệm các phản hồi DNS độc hại. Trình duyệt Chrome và Firefox đã sử dụng kỹ thuật ghim DNS để ngăn chặn hoặc ít nhất là giảm thiểu các cuộc tấn công liên kết lại DNS. Ghim DNS buộc trình duyệt phải lưu trữ đệm các kết quả DNS trong một khoảng thời gian cố định, bất kể TTL của các bản ghi DNS được đặt thành giá trị nào.

➤ Xác thực đầu vào

Xác thực và vệ sinh đầu vào trên máy khách và máy chủ để tránh các cuộc tấn công tiêm nhiễm tiềm ẩn. Ngoài ra, hãy lọc các ký tự có khả năng gây hại, áp dụng định dạng đầu vào và sử dụng danh sách trắng các giá trị được chấp thuận.

➤ Triển khai phân đoạn mạng

Tạo các phân đoạn riêng biệt bên trong mạng của bạn và áp dụng chính sách Zero Trust Network Access (ZTNA) . Trong trường hợp tấn công DNS rebinding thành công, tác động sẽ chỉ giới hạn ở phân đoạn mạng ban đầu bị xâm phạm.

➤ Không bao giờ bỏ lỡ một bản vá

Các tác nhân đe dọa liên tục quét lỗ hổng . Vì vậy, hãy đảm bảo rằng bạn và kíp thời máy chủ DNS, trình duyệt web và các tài sản khác của mình.

➤ Biết trình phân giải DNS của bạn

Chỉ sử dụng trình phân giải DNS được cấu hình để phát hiện và ngăn chặn các cuộc tấn công DNS rebinding. Tất nhiên, tính năng xác thực phản hồi DNS và DNSSEC là những tính năng bắt buộc phải có.

➤ Sử dụng cơ chế giới hạn tốc độ

Áp dụng cơ chế giới hạn tốc độ để tránh các truy vấn DNS quá mức từ một IP hoặc tên miền duy nhất. Tin tặc thường tạo ra khối lượng lớn yêu cầu DNS không mong muốn.

2.6 Đường hầm DNS (DNS Tunneling)

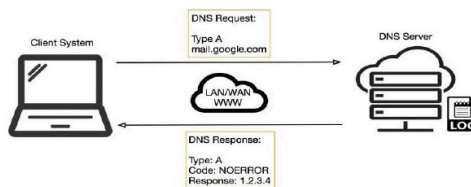
2.6.1 Đường hầm DNS là gì?

Đường hầm DNS là một cuộc tấn công khó phát hiện, định tuyến các yêu cầu DNS đến máy chủ của kẻ tấn công, cung cấp cho kẻ tấn công một kênh chỉ huy và điều khiển bí mật cũng như đường dẫn đánh cắp dữ liệu.

DNS giống như một danh bạ điện thoại cho internet, giúp dịch giữa các địa chỉ IP và tên miền. Con người không giỏi nhớ các chuỗi số dài. Một địa chỉ web (như extrahop.com/network-attack-library) dễ nhớ hơn và cho bạn biết một chút về nơi bạn đang đến. Vì trình duyệt web sử dụng địa chỉ IP, bạn cần một cái gì đó để dịch giữa

hai địa chỉ này.

Những kẻ xấu sử dụng đường hầm DNS để lấy dữ liệu qua tường lửa. Đường hầm DNS mã hóa các thông điệp chỉ huy và điều khiển (C&C) hoặc một lượng nhỏ dữ liệu thành các phản hồi và truy vấn DNS không dễ thấy. Vì các thông điệp DNS chỉ có thể chứa một lượng nhỏ dữ liệu, nên bất kỳ lệnh nào cũng phải nhỏ và việc rò rỉ dữ liệu diễn ra chậm. Lưu lượng DNS đáng ngờ có thể khó phát hiện vì DNS là một giao thức nhiễu, khiến việc phân biệt truy vấn máy chủ bình thường và lưu lượng DNS bình thường với hoạt động độc hại trở nên khó khăn hơn.



2.6.2 Đường hầm DNS hoạt động như thế nào

Các cuộc tấn công đường hầm DNS khai thác giao thức DNS để truyền phần mềm độc hại và dữ liệu khác thông qua mô hình máy khách-máy chủ.

- Kẻ tấn công đăng ký một tên miền, chẳng hạn như badsite.com. Máy chủ tên miền trở đến máy chủ của kẻ tấn công, nơi chương trình phần mềm độc hại đường hầm được cài đặt.
- Kẻ tấn công lây nhiễm phần mềm độc hại vào máy tính, thường nằm sau tường lửa của công ty. Vì các yêu cầu DNS luôn được phép đi chuyển vào và ra khỏi tường lửa, nên máy tính bị nhiễm được phép gửi truy vấn đến trình phân giải DNS. Trình phân giải DNS là máy chủ chuyển tiếp các yêu cầu về địa chỉ IP đến máy chủ tên miền gốc và cấp cao nhất.
- Bộ giải quyết DNS định tuyến truy vấn đến máy chủ chỉ huy và kiểm soát của kẻ tấn công, nơi chương trình đường hầm được cài đặt. Một kết nối hiện được thiết lập giữa nạn nhân và kẻ tấn công thông qua bộ giải quyết DNS. Đường hầm này có thể được sử dụng để đánh cắp dữ liệu hoặc cho các mục đích độc hại khác. Vì không có kết nối trực tiếp giữa kẻ tấn công và nạn nhân nên việc theo dõi máy tính của kẻ tấn công khó khăn hơn.

2.6.3 Ngăn chặn đường hầm DNS

Để ngăn chặn các cuộc tấn công đường hầm DNS, nhóm CNTT và bảo mật có thể áp dụng một số biện pháp bảo mật mạng tốt nhất.

- Tiến hành đào tạo nâng cao nhận thức về bảo mật để giúp nhân viên tránh nhấp vào các liên kết độc hại, mở email và tệp đính kèm đáng ngờ hoặc thực hiện các hành động khác có thể kích hoạt phần mềm độc hại.
- Triển khai công nghệ chống vi-rút và phần mềm độc hại tiên tiến để giúp tránh cài đặt phần mềm độc hại, thường là bước đầu tiên trong việc thiết lập đường hầm DNS.
- Triển khai công nghệ để thực hiện quét sâu toàn bộ lưu lượng mạng — bao gồm các yêu cầu DNS — nhằm phát hiện các cuộc tấn công đường hầm DNS.
- Giám sát các dịch vụ VPN đường hầm DNS, chẳng hạn như chương trình diệt vi-rút và các giải pháp bảo mật khác sử dụng đường hầm

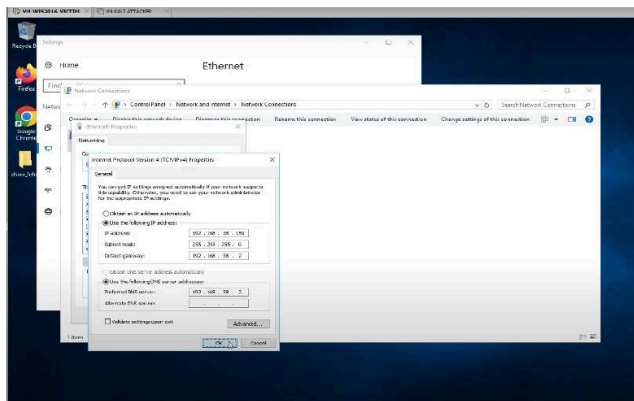
DNS dễ lấy chữ ký nhưng cũng có thể được sử dụng cho các lý do bất hợp pháp.

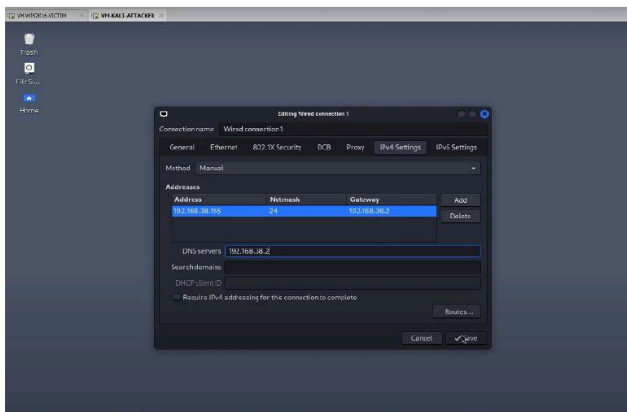
- Triển khai tường lửa DNS hoặc tiện ích đường hầm DNS để giám sát hành vi đáng ngờ.
- Áp dụng các giải pháp bảo vệ mối đe dọa tiên tiến để cải thiện bảo mật DNS, chặn phần mềm độc hại, ngăn chặn rò rỉ dữ liệu và phát hiện nội dung độc hại được nhúng trong lưu lượng DNS.

III. Demo hình thức tấn công

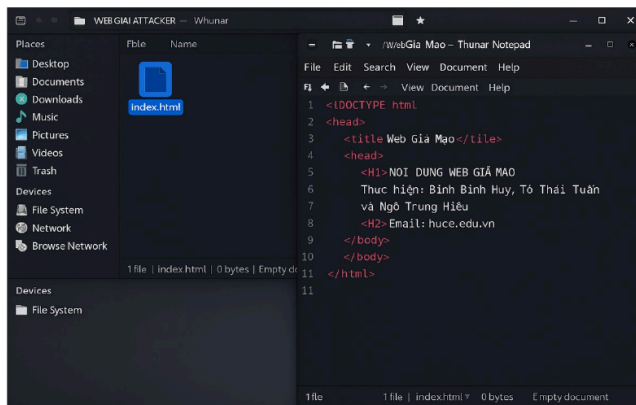
B1: Cài 2 máy ảo VM-WIN2016 và VM-KALI

B2: Thiết lập IP cho 2 máy VM-WIN2016 và VM-KALI

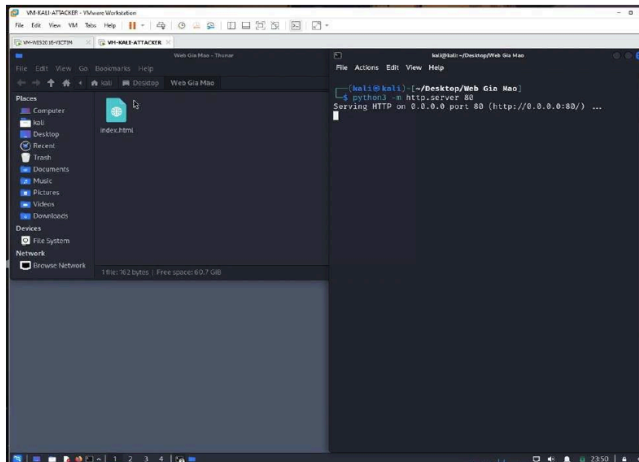




B3: Thiết lập Web Server giả mạo bằng python

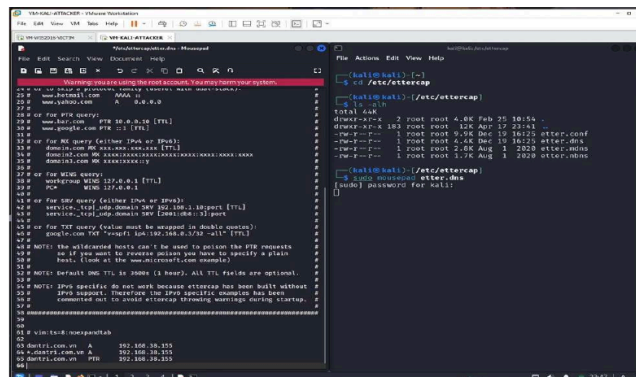


B4: Khởi chạy web server bằng lệnh python3 -m http.server 80



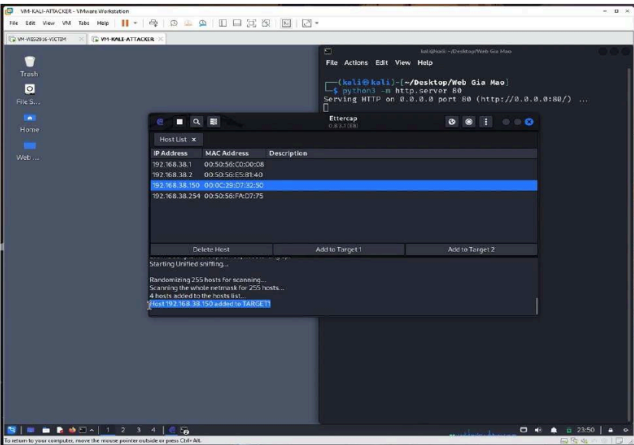
B5: Thiết lập Etter DNS (tùy chỉnh truy vấn DNS về trang giả mạo)

- Truy cập file etter.dns tại /etc/ettercap/etter.dns
- Thêm nội dung chuyển hướng truy vấn vào cuối file thiết lập



B6: Khởi chạy ETTERCAP bản có giao diện và thiết lập Host

B7: Chọn target 1 là máy VM-WIN2016 với địa chỉ IP là 192.168.38.150 và target 2 là tất cả các host còn lại và khởi chạy plugin “dns_spoofing”



B8: Truy cập vào trang web dantri thì ta sẽ thấy rằng chúng ta đang truy cập vào trang web giả mạo



IV. Kết luận

Hệ thống DNS (Domain Name System) đóng vai trò quan trọng trong việc chuyển đổi tên miền thành địa chỉ IP, giúp người dùng truy cập các trang web dễ dàng. Tuy nhiên, DNS cũng là mục tiêu của nhiều hình thức tấn

công mạng tính vi như DNS Spoofing, DNS Cache Poisoning, Man-in-the-Middle, DNS Hijacking, Pharming, DNS Rebinding, và DNS Tunneling. Các cuộc tấn công này nhằm mục đích chuyển hướng người dùng đến các trang web giả mạo, đánh cắp thông tin cá nhân, phát tán mã độc, hoặc thực hiện các hành vi gián điệp và theo dõi.

Mỗi hình thức tấn công có cơ chế hoạt động, rủi ro, và cách phòng ngừa riêng. Để bảo vệ khỏi các mối đe dọa này, cần triển khai các biện pháp bảo mật như:

- Sử dụng DNSSEC để xác thực dữ liệu DNS.
- Áp dụng mã hóa đầu cuối (HTTPS) và các công cụ phát hiện giả mạo DNS.
- Giám sát lưu lượng DNS, sử dụng tường lửa DNS, và cập nhật phần mềm thường xuyên.
- Nâng cao nhận thức bảo mật cho người dùng và quản trị viên mạng.

Tài liệu tham khảo

[1] *"Computer Security: Principles and Practice"* của William Stallings và Lawrie Brown: Sách này cung cấp thông tin chi tiết về các loại tấn công mạng, bao gồm DNS Spoofing, DNS Cache Poisoning, và MITM.

[2] *"Hacking Exposed: Network Security Secrets & Solutions"* của Stuart McClure, Joel Scambray, và George Kurtz: Cuốn sách này mô tả các kỹ thuật tấn công như DNS Hijacking và cách phòng ngừa.